CAHIER DES CHARGES

Cyber
Fightness

Auteur	David BEKALE
Version	2.0 – 2026

Table des matières

1. Introduction et contexte 4
1.1 Un secteur en pleine transformation numérique 4
1.2 Des données d'une sensibilité particulière 4
1.3 Un secteur déjà victime de cyberattaques 5
1.4 Objectifs et portée du document 5
2. Présentation du projet 6
2.1 Nature et approche du projet 6
2.2 Périmètre détaillé 7
2.3 Genèse du projet et problématique centrale 7
3. Objectifs du projet 8
3.1 Objectifs à destination des employés 8
3.2 Objectifs à destination des responsables IT 8
4. Cadre réglementaire et normatif 9
4.1 Le Règlement Général sur la Protection des Données (RGPD) 9
4.2 La directive NIS2 9
4.3 Normes et cadres de référence 9
5. Besoins fonctionnels 10
5.1 Classification et gestion des données sensibles 10
5.2 Définition d'une politique de sécurité interne 10
5.3 Gestion des accès et des identités (IAM) 10
5.4 Sauvegarde et continuité des activités 11
5.5 Journalisation et traçabilité 11
6. Besoins techniques 12
6.1 Segmentation du réseau (VLAN) 12
6.2 Pare-feu et filtrage 12
6.3 Authentification multi-facteur (MFA) 13
6.4 Chiffrement des données 13
6.5 Gestion des mises à jour et des correctifs 13
6.6 Sécurisation des applications et des API 13
7. Analyse des risques 14
7.1 Méthodologie : EBIOS Risk Manager 14
7.2 Cartographie des risques 14
7.3 Analyse détaillée des risques prioritaires 14
8. Organisation du projet 16
8.1 Équipe projet et parties prenantes 16
8.2 Gouvernance et pilotage 16
8.3 Méthodologie de travail 16
8.4 Planning prévisionnel 17

9. Plan de formation 18
9.1 Philosophie et principes pédagogiques 18
9.2 Module 1 – Sensibilisation à la valeur des données 18
9.3 Module 2 – Hygiène numérique au quotidien 18
9.4 Module 3 – Atelier anti-phishing 19
9.5 La charte informatique 19
10. Budget prévisionnel 20
11. Critères de réussite 21
11.1 Indicateurs de performance (KPI) 21
11.2 Critères de satisfaction de la direction 21
11.3 Amélioration continue 21

1. Introduction et contexte

1.1 Un secteur en pleine transformation numérique

Les salles de sport ont connu au cours de la dernière décennie une transformation profonde de leur fonctionnement. Ce qui était autrefois une activité essentiellement physique et locale est devenu un écosystème numérique complexe, intégrant des applications mobiles pour la réservation de cours, des portails web pour la gestion des abonnements, des terminaux de paiement connectés, des systèmes de contrôle d'accès par badge ou QR code, et même des équipements sportifs connectés capables de collecter des données biométriques en temps réel. La salle Fightness, comme l'ensemble de ses homologues du secteur, s'inscrit pleinement dans cette réalité numérique.

Cette évolution présente des avantages considérables pour les gestionnaires comme pour les adhérents : gain de temps, meilleure personnalisation des services, optimisation des ressources humaines et matérielles. Cependant, elle engendre simultanément une exposition croissante aux risques informatiques. Chaque nouveau service numérique représente une porte potentielle par laquelle un attaquant malveillant peut tenter de s'introduire. La question n'est donc plus de savoir si une salle de sport peut être victime d'une cyberattaque, mais comment s'y préparer et l'anticiper.

1.2 Des données d'une sensibilité particulière

Les informations manipulées quotidiennement au sein d'une salle de sport ne sont pas anodines. Il s'agit de données à caractère personnel au sens du Règlement Général sur la Protection des Données (RGPD) : noms, prénoms, adresses postales et électroniques, numéros de téléphone, dates de naissance, mais aussi et surtout des données financières telles que les coordonnées bancaires utilisées pour les prélèvements automatiques d'abonnements. Dans certains cas, on parle également de données de santé, notamment lorsque la salle propose un suivi médico-sportif, des bilans de condition physique ou lorsque les machines connectées enregistrent des paramètres physiologiques comme la fréquence cardiaque, le poids ou les performances.

Ces données sont particulièrement précieuses pour les cybercriminels. Une adresse email associée à un numéro de carte bancaire peut suffire pour mener des attaques de phishing ciblé. Les données de santé, quant à elles, sont considérées par la législation européenne comme des données sensibles soumises à un régime de protection renforcé. Leur divulgation peut avoir des conséquences graves pour les personnes concernées : usurpation d'identité, préjudice financier, atteinte à la vie privée.

1.3 Un secteur déjà victime de cyberattaques

Contrairement à ce que l'on pourrait croire, le secteur du fitness et des salles de sport n'est pas épargné par les cyberattaques. Plusieurs incidents majeurs ont déjà été répertoriés à l'échelle internationale, démontrant que les acteurs malveillants n'hésitent pas à cibler ces organisations, souvent moins bien protégées que les grandes entreprises, mais qui détiennent néanmoins des données de valeur.

L'un des cas les plus médiatisés est celui d'Under Armour et de son application MyFitnessPal, dont la fuite de données en 2018 a touché près de 150 millions d'utilisateurs dans le monde. Leurs adresses email, noms d'utilisateurs et mots de passe hachés ont été exposés, forçant l'entreprise à notifier ses utilisateurs en urgence et à mener une refonte complète de ses pratiques de sécurité. Plus récemment, la chaîne britannique Total Fitness a subi une attaque par ransomware qui a paralysé ses systèmes internes et compromis les données personnelles de milliers de membres. Town Sports International, groupe américain gérant plusieurs centaines de salles, a également vu les informations de ses clients et employés exposées suite à une faille de sécurité. En France, des enseignes comme Hello Gym ont été concernées par des incidents similaires.

Ces exemples ne sont pas de simples anecdotes : ils constituent des signaux d'alarme que le secteur ne peut plus ignorer. Chacun de ces incidents a entraîné des conséquences financières lourdes (amendes RGPD, coûts de remédiation, perte de confiance des clients), ainsi que des dommages durables pour la réputation des organisations concernées.

1.4 Objectifs et portée du document

C'est dans ce contexte que s'inscrit le présent cahier des charges. Son ambition est double : d'une part, poser un diagnostic lucide de la situation en matière de cybersécurité au sein d'une salle de sport comme Fightness ; d'autre part, proposer un plan d'action concret, structuré et réaliste pour y remédier. Ce document s'adresse à la fois à la direction générale, aux responsables informatiques et à l'ensemble du personnel. Il ne s'agit pas d'un document purement technique réservé aux informaticiens, mais d'un guide opérationnel que chaque partie prenante doit pouvoir s'approprier selon son niveau de responsabilité.

Le périmètre de ce cahier des charges couvre l'ensemble des systèmes d'information de la salle Fightness : les postes de travail des employés, les terminaux de caisse et de contrôle d'accès, les caméras de vidéosurveillance, les équipements sportifs connectés (IoT), le réseau Wi-Fi accessible aux clients et aux collaborateurs, ainsi que les applications web et mobiles utilisées par les adhérents.

2. Présentation du projet

2.1 Nature et approche du projet

Ce projet se distingue volontairement des démarches purement techniques de développement informatique. Il s'agit d'un travail d'analyse, de conseil et de structuration en matière de cybersécurité, appliqué à un environnement concret et quotidien : la salle de sport. L'approche retenue est délibérément holistique, c'est-à-dire qu'elle ne traite pas la sécurité informatique comme un problème exclusivement technologique, mais comme un enjeu humain, organisationnel et technique à la fois.

La conviction qui guide ce projet est que la cybersécurité ne peut pas reposer uniquement sur des outils, aussi performants soient-ils. Un pare-feu dernier cri ne protégera pas une organisation dont les employés cliquent sur chaque lien reçu par email. À l'inverse, des équipes parfaitement sensibilisées ne pourront pas compenser l'absence de segmentation réseau ou le manque de sauvegardes régulières. C'est pourquoi ce projet articule deux axes indissociables : la formation humaine et le renforcement des infrastructures.

2.2 Périmètre détaillé

Le périmètre de ce projet englobe l'ensemble des acteurs et des systèmes qui participent au fonctionnement numérique de Fightness. Du côté humain, on distingue trois catégories : les employés en contact direct avec les adhérents (hôtes d'accueil, coachs), les personnels administratifs qui gèrent les contrats, les paiements et les plannings, et enfin les responsables techniques chargés de l'administration des systèmes informatiques. Du côté technique, le périmètre comprend les postes de travail fixes et mobiles, les serveurs de données (qu'ils soient hébergés en local ou dans le cloud), les équipements réseau (routeurs, switches, bornes Wi-Fi), les systèmes d'encaissement et de contrôle d'accès, les caméras de vidéosurveillance, et l'ensemble des objets connectés présents dans la salle (tapis de course, vélos elliptiques, appareils de musculation équipés d'écrans connectés).

Il est important de noter que les adhérents eux-mêmes ne sont pas acteurs du projet, mais en sont les premiers bénéficiaires : la protection de leurs données personnelles est la finalité ultime de l'ensemble des mesures proposées dans ce document.

2.3 Genèse du projet et problématique centrale

Ce projet est né d'une volonté d'allier une passion personnelle pour le sport et la musculation avec une réflexion professionnelle sur la cybersécurité. En observant le fonctionnement quotidien des salles de sport et en prenant conscience de la quantité de données sensibles qui y sont traitées chaque jour, la question s'est imposée naturellement : ces organisations sont-elles suffisamment préparées face aux menaces numériques ?

La réponse, à la lumière des incidents documentés et des pratiques observées sur le terrain, est clairement non. Les salles de sport ont investi massivement dans leur transformation numérique sans toujours en mesurer les risques. Les employés ne reçoivent généralement aucune formation en cybersécurité. Les infrastructures réseau sont souvent configurées de manière sommaire. La question de la conformité RGPD est traitée de façon minimale. C'est précisément pour combler ce vide que ce cahier des charges a été élaboré.

3. Objectifs du projet

3.1 Objectifs à destination des employés

Le premier grand axe de ce projet vise à transformer la culture interne de l'organisation face aux risques numériques. Les employés de salle de sport ne sont pas des informaticiens, et il serait illusoire de vouloir en faire des experts en cybersécurité. L'objectif est plus modeste mais tout aussi ambitieux dans sa portée : faire en sorte que chaque membre du personnel adopte des réflexes simples qui réduisent considérablement la surface d'attaque de l'organisation.

Concrètement, il s'agit de sensibiliser chaque employé à la valeur et à la sensibilité des données qu'il manipule au quotidien. Un hôte d'accueil qui saisit les coordonnées bancaires d'un nouveau membre doit comprendre pourquoi ces informations doivent être traitées avec la plus grande prudence. Un coach qui utilise une tablette pour consulter les fiches de suivi de ses clients doit savoir pourquoi il doit verrouiller l'écran dès qu'il s'éloigne. Un responsable administratif qui reçoit un email lui demandant de mettre à jour ses identifiants doit être capable de reconnaître une tentative de phishing.

Les objectifs opérationnels pour les employés sont les suivants : être capable d'identifier un email ou un message suspect, adopter des mots de passe robustes et ne jamais les partager, verrouiller systématiquement son poste de travail lors de chaque déplacement, ne jamais connecter de clé USB dont l'origine est inconnue, et respecter scrupuleusement la confidentialité des données des adhérents, tant en termes d'accès que de divulgation.

3.2 Objectifs à destination des responsables IT

Le second axe est directement technique et s'adresse aux personnes chargées d'administrer et de maintenir les systèmes informatiques de Fightness. Ces objectifs sont plus complexes à mettre en œuvre mais tout aussi fondamentaux.

Il s'agit en premier lieu de procéder à un état des lieux complet de l'infrastructure existante afin d'identifier les failles et les configurations inadéquates. Sur cette base, le responsable IT devra concevoir et déployer une architecture réseau segmentée, avec des zones distinctes pour les clients, les employés et les équipements connectés. Il lui reviendra également de mettre en place des outils de détection des intrusions, de configurer des sauvegardes automatiques et régulières, de gérer les droits d'accès de manière rigoureuse selon le principe du moindre privilège, et d'assurer la mise à jour continue de l'ensemble des logiciels et systèmes.

Un objectif transversal concerne la conformité réglementaire : le responsable IT, en lien avec la direction, doit s'assurer que le traitement des données personnelles est conforme aux exigences du RGPD, notamment en ce qui concerne la durée de conservation des données, les droits des personnes (accès, rectification, effacement) et les procédures de notification en cas de violation de données.

4. Cadre réglementaire et normatif

4.1 Le Règlement Général sur la Protection des Données (RGPD)

Le RGPD, entré en vigueur le 25 mai 2018, constitue le texte fondateur de toute démarche de protection des données personnelles en Europe. Il s'applique à toute organisation qui collecte, traite ou stocke des données personnelles de résidents européens, quelle que soit la taille de la structure. Une salle de sport comme Fightness y est donc pleinement soumise.

Concrètement, le RGPD impose plusieurs obligations majeures. En premier lieu, le principe de minimisation des données : on ne collecte que les informations strictement nécessaires à la finalité du service. En deuxième lieu, le principe de limitation de la conservation : les données ne doivent pas être conservées au-delà de la durée nécessaire. En troisième lieu, les droits des personnes concernées doivent être respectés et facilement exercés : droit d'accès, de rectification, d'effacement, de portabilité. Enfin, en cas de violation de données (fuite, piratage), l'organisation a l'obligation de notifier la CNIL dans un délai de 72 heures et d'informer les personnes concernées si la violation présente un risque élevé pour leurs droits et libertés. Le non-respect de ces obligations peut entraîner des sanctions pouvant aller jusqu'à 4 % du chiffre d'affaires mondial ou 20 millions d'euros.

4.2 La directive NIS2

La directive européenne NIS2 (Network and Information Security 2), transposée en droit français, renforce les exigences en matière de sécurité des réseaux et des systèmes d'information pour un large spectre d'organisations. Bien que les salles de sport ne soient pas directement désignées comme entités essentielles au sens de NIS2, les principes qu'elle porte (gestion des risques, signalement des incidents, sécurité de la chaîne d'approvisionnement) constituent une référence pertinente et de bonnes pratiques à adopter.

4.3 Normes et cadres de référence

Au-delà de la réglementation, plusieurs normes internationales encadrent les bonnes pratiques en matière de cybersécurité et serviront de références tout au long de ce projet. La norme ISO/IEC 27001 définit les exigences pour un système de management de la sécurité de l'information (SMSI). Elle permet de structurer de façon méthodique l'ensemble des mesures de sécurité. Le NIST Cybersecurity Framework, développé par l'Institut américain des normes et technologies, propose une approche structurée en cinq fonctions : Identifier, Protéger, Détecter, Répondre et Récupérer. Enfin, la méthode EBIOS Risk Manager, développée par l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information), sera utilisée comme cadre méthodologique pour l'analyse des risques présentée dans ce document.

5. Besoins fonctionnels

Les besoins fonctionnels décrivent ce que le système de cybersécurité doit permettre de faire au quotidien, indépendamment des technologies utilisées pour y parvenir. Ce sont les fonctions attendues du plan de sécurité, les objectifs pratiques qui serviront de boussole à toute la démarche.

5.1 Classification et gestion des données sensibles

La première exigence fonctionnelle consiste à mettre en place un référentiel de classification des données. Toutes les informations traitées par Fightness n'ont pas le même niveau de sensibilité, et il est indispensable de les hiérarchiser pour leur appliquer des mesures de protection proportionnées. On distinguera trois niveaux : les données publiques (horaires, tarifs, informations commerciales), les données internes (plannings employés, statistiques de fréquentation), et les données confidentielles (informations personnelles et bancaires des adhérents, données de santé, identifiants d'accès). Cette classification permettra d'orienter les efforts de protection là où ils sont le plus nécessaires.

5.2 Définition d'une politique de sécurité interne

La politique de sécurité est le document central qui formalise les règles du jeu au sein de l'organisation. Elle doit définir clairement ce qui est autorisé et ce qui est interdit : utilisation des ressources informatiques, gestion des mots de passe, politique de navigation web, règles relatives aux données clients, procédures à suivre en cas de doute ou d'incident. Cette politique ne doit pas être un document abstrait et inaccessible, mais un guide pratique, rédigé en langage clair, que chaque employé peut consulter facilement et qu'il s'engage à respecter par la signature d'une charte informatique.

5.3 Gestion des accès et des identités (IAM)

Le contrôle des accès est une pierre angulaire de la sécurité informatique. L'organisation doit être en mesure de définir avec précision qui a accès à quoi, et dans quelles conditions. Chaque employé doit disposer d'un compte individuel nominatif, en aucun cas partagé. Les droits d'accès doivent être attribués selon le principe du moindre privilège : un coach n'a pas besoin d'accéder aux données financières de l'entreprise, et un hôte d'accueil n'a pas à consulter les fiches médicales détaillées des adhérents. Cette gestion fine des droits limite considérablement les risques liés à une compromission de compte ou à une malveillance interne.

5.4 Sauvegarde et continuité des activités

La sauvegarde régulière des données est une mesure de protection essentielle, particulièrement face au risque de ransomware qui consiste à chiffrer les données de la victime et à exiger une rançon pour les déchiffrer. Pour être efficace, une politique de sauvegarde doit respecter la règle des 3-2-1 : trois copies des données, sur deux supports différents, dont une copie hors site (dans le cloud ou sur un serveur distant). Ces sauvegardes doivent être testées régulièrement pour s'assurer qu'elles sont effectivement restaurables en cas de besoin.

5.5 Journalisation et traçabilité

L'organisation doit être capable de répondre à une question simple mais fondamentale en cas d'incident : que s'est-il passé, quand, et qui en est responsable ? La journalisation (ou logging) consiste à enregistrer automatiquement les événements significatifs du système : connexions réussies et échouées, modifications de données sensibles, accès à des ressources critiques, alertes de sécurité. Ces journaux sont indispensables pour mener une enquête après un incident, mais aussi pour détecter en temps réel des comportements anormaux.

6. Besoins techniques

Les besoins techniques traduisent en solutions concrètes les objectifs fonctionnels définis précédemment. Ils constituent la colonne vertébrale opérationnelle du plan de sécurité et s'adressent principalement aux responsables informatiques de Fightness.

6.1 Segmentation du réseau (VLAN)

La mesure technique la plus fondamentale à mettre en œuvre est la séparation du réseau informatique en plusieurs zones isolées, appelées VLAN (Virtual Local Area Network). Cette segmentation permet de contenir la propagation d'une attaque : si un équipement d'une zone est compromis, l'attaquant ne peut pas se déplacer librement vers les autres zones.

Trois segments distincts doivent être créés. Le réseau invité est accessible aux adhérents via le Wi-Fi de la salle. Il donne accès à Internet mais est totalement isolé des systèmes internes. Même si un client est victime d'une attaque sur ce réseau, l'attaquant ne pourra atteindre ni les serveurs, ni les caisses, ni les caméras de Fightness. Le réseau interne est réservé aux postes de travail des employés, aux serveurs de données, aux terminaux d'encaissement et aux systèmes de badges d'accès. Il donne accès à toutes les ressources internes mais est protégé par des règles strictes. Le réseau IoT est dédié aux équipements sportifs connectés (tapis de course, vélos, appareils intelligents). Ces équipements sont souvent peu sécurisés et représentent une cible privilégiée pour les attaquants. Les isoler dans un segment dédié empêche qu'ils ne deviennent une porte d'entrée vers le cœur du système.

Exemple concret : sans segmentation réseau

Sans VLAN, un attaquant qui se connecte au Wi-Fi clients peut scanner le réseau et atteindre les serveurs internes. Avec la segmentation, même en étant connecté au réseau invité, il est dans une bulle isolée sans aucun accès aux ressources sensibles.

6.2 Pare-feu et filtrage

Un pare-feu (firewall) est un dispositif matériel ou logiciel qui contrôle les flux de données entrants et sortants du réseau selon des règles prédéfinies. Il constitue la première ligne de défense contre les attaques externes. Pour Fightness, un pare-feu doit être positionné entre le réseau interne et Internet, mais aussi entre les différents segments VLAN pour contrôler finement les communications inter-zones. Les règles de filtrage doivent être configurées selon le principe du moindre accès : tout ce qui n'est pas explicitement autorisé est interdit par défaut.

6.3 Authentification multi-facteur (MFA)

L'authentification multi-facteur est une mesure simple à déployer mais d'une efficacité redoutable. Elle consiste à exiger, en plus du mot de passe, une seconde preuve d'identité avant d'accorder l'accès à un système : un code envoyé par SMS, une notification sur une application mobile, ou une clé physique. Selon les statistiques publiées par Microsoft, 99,9 % des attaques de type compromission de compte sont bloquées par le MFA. Cette mesure doit être déployée en priorité sur les comptes administrateurs, les accès aux systèmes de gestion des adhérents et les accès aux systèmes de paiement.

6.4 Chiffrement des données

Le chiffrement est le processus qui transforme des données lisibles en données illisibles pour quiconque ne dispose pas de la clé de déchiffrement. Il doit être appliqué à deux niveaux. Le chiffrement en transit protège les données lorsqu'elles circulent sur le réseau : les sites web et applications doivent utiliser le protocole HTTPS (TLS), et toutes les communications réseau sensibles doivent être chiffrées. Le chiffrement au repos protège les données stockées sur les serveurs et les disques durs : les bases de données contenant les informations des adhérents doivent être chiffrées, de sorte que même en cas de vol physique du serveur, les données restent inaccessibles.

6.5 Gestion des mises à jour et des correctifs

La majorité des cyberattaques réussies exploitent des vulnérabilités connues dans des logiciels non mis à jour. La gestion rigoureuse des mises à jour (patch management) est donc une mesure de prévention fondamentale. Elle concerne tous les systèmes : systèmes d'exploitation des serveurs et postes de travail, applications métier, logiciels de gestion des abonnements, firmwares des équipements réseau et des objets connectés. Un calendrier de mise à jour doit être établi, et les mises à jour de sécurité critiques doivent être appliquées dans les 48 à 72 heures suivant leur publication.

6.6 Sécurisation des applications et des API

Fightness propose vraisemblablement un espace client en ligne (réservation de cours, consultation du planning, gestion de l'abonnement) et utilise des API pour communiquer avec des prestataires tiers (paiement, marketing). Ces interfaces sont des cibles fréquentes pour les attaquants. Il est nécessaire de s'assurer que ces applications sont développées ou configurées selon les bonnes pratiques de sécurité : protection contre les injections SQL, validation des données saisies par les utilisateurs, limitation du nombre de tentatives de connexion, chiffrement des données transmises.

7. Analyse des risques

7.1 Méthodologie : EBIOS Risk Manager

L'analyse des risques a été conduite selon la méthode EBIOS Risk Manager (Expression des Besoins et Identification des Objectifs de Sécurité), élaborée par l'ANSSI et reconnue comme référence nationale en matière d'appréciation du risque numérique. Cette méthode repose sur l'identification des biens à protéger, des sources de menaces, des scénarios d'attaque et de leur impact potentiel sur l'organisation.

Pour chaque menace identifiée, deux dimensions sont évaluées. La probabilité d'occurrence, notée sur trois niveaux (faible, moyenne, élevée), représente la vraisemblance que la menace se concrétise compte tenu du contexte de l'organisation. L'impact potentiel, également noté sur trois niveaux (mineur, sérieux, critique), représente les conséquences pour l'organisation si la menace se matérialise. Ces deux dimensions combinées permettent d'obtenir un niveau de risque global et de prioriser les actions de traitement.

7.2 Cartographie des risques

Menace identifiée	Probabilité	Impact	Niveau de risque	Mesure prioritaire
Phishing (employés)	Élevée	Sérieux	CRITIQUE	Formation anti-phishing
Ransomware	Moyenne	Critique	CRITIQUE	Sauvegardes + EDR
IoT vulnérable	Moyenne	Critique	CRITIQUE	Segmentation réseau
Mauvaise configuration	Élevée	Sérieux	ÉLEVÉ	Audit config + procédures
Vol interne de données	Faible	Sérieux	MODÉRÉ	Contrôle d'accès IAM
Fuite via app mobile	Moyenne	Sérieux	ÉLEVÉ	Sécurisation API/HTTPS
Accès WiFi non cloisonné	Élevée	Critique	CRITIQUE	VLAN + pare-feu

7.3 Analyse détaillée des risques prioritaires

7.3.1 Le phishing

Le phishing est la menace la plus courante et la plus efficace dans le contexte des salles de sport. Un employé reçoit un email qui semble provenir d'un fournisseur, d'une banque ou d'un service interne, lui demandant de cliquer sur un lien et de saisir ses identifiants. La page vers laquelle il est redirigé est une copie conforme d'un site légitime, mais les informations saisies sont directement transmises à l'attaquant. En possession des identifiants d'un employé, l'attaquant peut accéder aux systèmes internes, consulter et exfiltrer les données des adhérents, voire

déposer un programme malveillant sur le réseau. La probabilité est élevée car ce type d'attaque est facile à mener, peu coûteux et ne requiert aucune compétence technique avancée.

7.3.2 Le ransomware

Une attaque par ransomware consiste à infecter les systèmes d'une organisation avec un logiciel malveillant qui chiffre l'ensemble des données et exige le paiement d'une rançon pour les déchiffrer. Pour une salle de sport, les conséquences peuvent être dévastatrices : impossibilité d'accéder aux données des adhérents, paralysie des systèmes de caisse et de contrôle d'accès, interruption totale de l'activité. Les ransomwares se propagent généralement via des emails de phishing ou en exploitant des vulnérabilités dans des logiciels non mis à jour. La mise en place de sauvegardes régulières et testées est la principale mesure de résilience contre ce type d'attaque.

7.3.3 Les équipements IoT vulnérables

Les objets connectés présents dans une salle de sport (tapis de course connectés, vélos intelligents, capteurs de performance, écrans interactifs) représentent une menace souvent sous-estimée. Ces équipements sont fréquemment configurés avec des mots de passe par défaut que leurs propriétaires ne pensent pas à changer, et leurs fabricants ne publient pas toujours des mises à jour de sécurité régulières. Un attaquant qui parvient à prendre le contrôle d'un de ces équipements peut, s'il n'y a pas de segmentation réseau, l'utiliser comme point de départ pour accéder à l'ensemble du système informatique de la salle. L'impact potentiel est critique car cela peut ouvrir la porte à toutes les données internes.

8. Organisation du projet

8.1 Équipe projet et parties prenantes

La réussite d'un projet de cybersécurité repose avant tout sur l'implication et l'alignement de l'ensemble des parties prenantes. Il ne peut pas être le projet exclusif d'une seule personne ou d'un seul département. Voici les acteurs clés identifiés pour ce projet :

Acteur	Rôle	Responsabilités
Direction Fightness	Commanditaire	Validation des choix stratégiques, arbitrages budgétaires, engagement dans la démarche sécurité
Responsable IT	Maître d'œuvre technique	Mise en œuvre des mesures techniques, maintenance des systèmes, gestion des accès
RSSI (ou consultant)	Pilote sécurité	Rédaction de la politique de sécurité, suivi des incidents, conformité RGPD, audits
Responsable RH	Relais humain	Organisation des formations, signature des chartes, gestion des départs et arrivées
Employés / Coaches	Utilisateurs finaux	Application des bonnes pratiques, remontée d'incidents, respect de la charte informatique
Prestataires externes	Tiers	Respect des exigences de sécurité contractualisées lors de leurs interventions

8.2 Gouvernance et pilotage

La gouvernance du projet sera assurée par un comité de pilotage réunissant la direction, le responsable IT et le RSSI (ou consultant en charge de la sécurité). Ce comité se réunira mensuellement pendant la phase de déploiement et trimestriellement en phase de maintenance, afin de suivre l'avancement des actions, arbitrer les priorités et valider les décisions stratégiques. Un tableau de bord de suivi sera maintenu à jour et partagé avec l'ensemble des parties prenantes.

8.3 Méthodologie de travail

Le projet sera conduit selon une approche agile adaptée, organisée en sprints de deux semaines. Cette méthode a été retenue pour sa capacité à s'adapter aux contraintes opérationnelles d'une salle de sport, dont l'activité ne peut pas être interrompue pour des raisons informatiques. Chaque sprint débute par une réunion de planification, se déroule avec des points d'avancement réguliers, et se conclut par une revue permettant de valider les livrables et d'ajuster le plan si nécessaire. Cette approche itérative garantit que les mesures les plus urgentes sont déployées en priorité, sans attendre la fin d'un long projet monolithique.

8.4 Planning prévisionnel

Le déploiement du projet est organisé en quatre phases principales, chacune ayant des livrables clairement identifiés. La phase de diagnostic, d'une durée de deux semaines, consiste à réaliser un audit complet de l'existant : inventaire des actifs, cartographie du réseau, évaluation des pratiques actuelles des employés, analyse de conformité RGPD. La phase de conception, d'une durée de trois semaines, produit les livrables documentaires : politique de sécurité, charte informatique, plan de formation, architecture réseau cible. La phase de déploiement, d'une durée de six semaines, correspond à la mise en œuvre des mesures techniques et à la conduite des sessions de formation. La phase de contrôle, continue à partir de la semaine douze, consiste à vérifier l'efficacité des mesures déployées par des audits et des simulations, et à ajuster le dispositif en conséquence.

9. Plan de formation

9.1 Philosophie et principes pédagogiques

La formation en cybersécurité destinée aux employés d'une salle de sport ne peut pas reprendre les mêmes codes qu'une formation destinée à des informaticiens. Le public cible a des contraintes de temps importantes (disponibilités entre les créneaux de coaching, permanences à l'accueil), un niveau de familiarité avec le sujet très variable, et des besoins très pragmatiques. La formation doit donc être courte, concrète, immédiatement applicable et, dans la mesure du possible, engageante.

L'approche pédagogique retenue repose sur trois principes. La contextualisation : chaque notion est illustrée par des exemples tirés du quotidien de la salle de sport (et non d'environnements bancaires ou industriels qui parleraient moins aux participants). La progressivité : les concepts les plus simples et les plus urgents sont abordés en premier, avant de traiter des sujets plus complexes. L'interactivité : les formations incluent des exercices pratiques, des mises en situation et des quiz qui favorisent la mémorisation et l'engagement.

9.2 Module 1 – Sensibilisation à la valeur des données

Ce premier module, d'une durée d'environ une heure, vise à créer une prise de conscience. Les employés doivent comprendre, de façon concrète et émotionnellement parlante, pourquoi les données qu'ils manipulent chaque jour ont de la valeur et quelles peuvent être les conséquences d'une négligence. On leur présentera des cas réels (MyFitnessPal, Total Fitness) et on leur expliquera ce qu'il advient des données volées : revente sur le dark web, usurpation d'identité, fraude bancaire. L'objectif est de sortir de l'abstraction pour ancrer la notion de risque dans le réel.

Les notions abordées dans ce module sont : la définition d'une donnée personnelle au sens du RGPD, les catégories de données traitées par Fightness et leur niveau de sensibilité, les obligations légales de l'organisation et les droits des personnes concernées, et les conséquences potentielles d'une violation de données pour l'organisation et pour les adhérents.

9.3 Module 2 – Hygiène numérique au quotidien

Ce deuxième module, d'une durée d'environ deux heures incluant des exercices pratiques, aborde les bonnes pratiques concrètes que chaque employé doit adopter dans son travail quotidien. Le contenu est délibérément opérationnel et centré sur des actions simples mais dont l'impact sur la sécurité est majeur.

Les thèmes traités comprennent la création et la gestion de mots de passe robustes : utilisation d'une phrase de passe, règles de complexité minimale, interdiction absolue de partager ses identifiants, et présentation des gestionnaires de mots de passe comme solution pratique. Le verrouillage automatique des postes de travail et des terminaux mobiles est expliqué et démontré en pratique. La gestion des supports amovibles est abordée : les clés USB inconnues ne doivent jamais être connectées, même si elles semblent avoir été oubliées par un collègue. Enfin, les

règles de confidentialité sont rappelées : ne jamais discuter de données clients dans des espaces publics, ne pas laisser des fiches d'adhérents visibles sur un bureau ou un écran.

9.4 Module 3 – Atelier anti-phishing

Ce module, d'une durée d'environ deux heures en format atelier interactif, est sans doute le plus important du plan de formation. Il vise à donner aux employés les réflexes nécessaires pour identifier et gérer correctement les tentatives d'hameçonnage, qui représentent le vecteur d'attaque le plus fréquent dans leur contexte.

L'atelier commence par la présentation de plusieurs exemples réels de mails de phishing, en expliquant les signes révélateurs qui permettent de les identifier : légères variations dans l'adresse email de l'expéditeur, ton d'urgence artificielle, liens pointant vers des domaines suspects, demandes inhabituelles (fournir ses identifiants, effectuer un virement urgent). Des exercices pratiques mettent les participants face à une série de messages (emails, SMS) et leur demandent de distinguer les vrais des faux. La procédure à suivre en cas de doute est clairement expliquée : ne pas cliquer, ne rien télécharger, signaler le message au responsable IT. Des simulations de phishing seront également menées trimestriellement afin de mesurer la progression et de maintenir la vigilance dans la durée.

9.5 La charte informatique

La charte informatique est le document qui formalise les droits et les obligations de chaque employé en matière d'utilisation des ressources informatiques. Elle constitue à la fois un outil pédagogique et un engagement contractuel. Chaque employé devra la lire, en accuser réception et la signer lors de son intégration, et lors de chaque mise à jour majeure.

La charte couvrira les thèmes suivants : les règles d'utilisation des équipements informatiques de l'entreprise, la politique de mots de passe, les règles de navigation sur Internet et d'utilisation de la messagerie, l'interdiction de l'installation de logiciels non autorisés, les obligations de confidentialité relatives aux données des adhérents, la procédure de signalement d'un incident ou d'un comportement suspect, et les sanctions encourues en cas de manquement. Elle sera rédigée en langage clair et accessible, sans jargon technique inutile.

10. Budget prévisionnel

La mise en œuvre d'un plan de cybersécurité représente un investissement, mais il doit être mis en perspective avec le coût d'un incident non préparé : une attaque par ransomware peut coûter plusieurs dizaines de milliers d'euros entre les pertes d'exploitation, les frais de remédiation, les amendes RGPD et la perte de clients. Le tableau ci-dessous présente une estimation des coûts associés à la première année de déploiement du plan.

Poste de dépense	Coût estimé (€ HT)	Remarques
Formation du personnel (ateliers, supports)	1 500 – 3 000	Selon taille de l'équipe et format retenu
Mise en place pare-feu + VLAN	1 000 – 2 500	Matériel + configuration initiale
Solution MFA (licences)	200 – 600 / an	Ex. : Duo Security, Microsoft Authenticator
Sauvegarde cloud sécurisée	300 – 800 / an	Ex. : Acronis, Backblaze Business
Audit de sécurité initial + pentest	2 000 – 5 000	Prestataire externe recommandé
Antivirus / EDR pour postes de travail	300 – 700 / an	Protection avancée des endpoints
Conseil RGPD et rédaction de la charte	500 – 1 500	Juriste ou DPO externe
TOTAL ESTIMÉ	**5 800 – 14 100 €**	**Sur 1ère année (investissement + abonnements)**

Il est important de préciser que ces estimations sont données à titre indicatif et varient en fonction de la taille de la structure, des prestataires retenus et des solutions technologiques choisies. Certains postes, comme la mise en place du pare-feu ou l'audit de sécurité, constituent des investissements ponctuels. D'autres, comme les licences MFA ou les sauvegardes cloud, génèrent des coûts récurrents annuels. La direction de Fightness devra arbitrer en fonction de ses priorités et de sa capacité d'investissement, en sachant que les mesures à faible coût (formation, politique de mots de passe, segmentation réseau) offrent souvent le meilleur retour sur investissement en termes de réduction du risque.

11. Critères de réussite

11.1 Indicateurs de performance (KPI)

La réussite d'un projet de cybersécurité ne se mesure pas uniquement à l'absence d'incident, même si c'est évidemment l'objectif ultime. Elle se mesure également à la maturité de l'organisation, à sa capacité à détecter et répondre aux incidents, et à l'adoption effective des bonnes pratiques par les équipes. Les indicateurs de performance suivants seront suivis tout au long du projet et permettront d'évaluer son efficacité.

- Taux de participation aux formations : objectif 100 % des employés formés dans les trois mois suivant le lancement.
- Taux de signature de la charte informatique : objectif 100 % des employés avant la fin de la phase de déploiement.
- Résultats des simulations de phishing : objectif une réduction de 50 % du taux de clics sur les liens suspects entre la première et la troisième simulation.
- Conformité de l'architecture réseau : validation par audit externe de la segmentation VLAN et de la configuration du pare-feu.
- Couverture des sauvegardes : 100 % des données critiques sauvegardées et testées (restauration testée chaque trimestre).
- Délai moyen de déploiement des mises à jour de sécurité : objectif inférieur à 72 heures pour les correctifs critiques.
- Nombre d'incidents de sécurité déclarés : indicateur suivi sur six mois pour mesurer la tendance.

11.2 Critères de satisfaction de la direction

Au-delà des indicateurs techniques, la direction de Fightness pourra considérer le projet comme un succès si plusieurs conditions sont réunies à l'issue de la phase de déploiement. L'organisation doit être capable de démontrer sa conformité au RGPD lors d'un contrôle de la CNIL, avec notamment l'existence d'un registre des traitements, d'une politique de gestion des données et de procédures de notification en cas de violation. Les employés doivent avoir intégré les bons réflexes : un test surprise doit montrer que la grande majorité d'entre eux verrouillent leur poste, utilisent des mots de passe robustes et savent à qui signaler un email suspect.

L'infrastructure technique doit avoir été auditée et validée par un prestataire externe spécialisé. Aucune vulnérabilité critique ne doit subsister dans les systèmes exposés à Internet. Enfin, et c'est peut-être le signe le plus fort de réussite, la cybersécurité doit être perçue au sein de l'organisation non plus comme une contrainte imposée de l'extérieur, mais comme une responsabilité partagée et une valeur ajoutée que Fightness peut mettre en avant auprès de ses adhérents comme gage de confiance et de sérieux.

11.3 Amélioration continue

La cybersécurité n'est pas un état statique à atteindre une bonne fois pour toutes. C'est un processus continu d'adaptation face à des menaces qui évoluent constamment. Ce cahier des charges doit donc être considéré comme un document vivant, révisé au minimum une fois par an et à chaque événement significatif (nouveau service numérique, changement d'organisation,

incident de sécurité). Des audits de sécurité annuels permettront de mesurer l'évolution du niveau de maturité et d'identifier les nouvelles priorités. La veille sur les menaces émergentes sera assurée par le responsable IT et/ou le RSSI, en s'appuyant sur les publications de l'ANSSI et les alertes du CERT-FR.

— Fin du document —